

ALA:4

Name: Parmar Vishva j .
Enrolment No: 240905091015
Course: BET-/IT
Subject: Cloud Computing (BETCE17336)

ALA 4

Cloud Risk & SLA Evaluation (Industry Case Study): In this activity, each student will perform a detailed case study on a realworld cloud service provider to analyze Service Level Agreements (SLA), risk management strategies, and compliance frameworks. They will evaluate security challenges, identify potential risks, and propose mitigation strategies based on industry standards. The study should include comparison of SLAs across providers, identification of gaps, and recommendations for improvement. Students will submit a structured analytical report with real-world references and upload it on the GMIU portal.

Solution

1. Executive Summary

This analytical report evaluates Service Level Agreements (SLAs), enterprise risk profiles, and regulatory compliance frameworks across leading Cloud Service Providers (CSPs), with an in-depth case study on **Amazon Web Services (AWS)** alongside a comparative analysis with **Microsoft Azure** and **Google Cloud Platform (GCP)**. The report assesses critical operational and legal gaps within standard cloud contracts, analyzes common industry risk failure modes, and outlines mitigation strategies mapped to industry standards.

2. Service Level Agreement (SLA) Architecture

An SLA defines the contractual commitment between a CSP and a customer regarding availability, performance, and remediation terms.

2.1 Anatomy of a Standard Cloud SLA

- **Service Commitment:** Typically expressed as a Monthly Uptime Percentage (MUP):

$$\text{Monthly Uptime \%} = \frac{\text{Total Minutes in Month} - \text{Downtime Minutes}}{\text{Total Minutes in Month}} \times 100$$

- **Multi-AZ vs. Single-Instance Commitments:** CSPs rarely provide 99.99% availability for standalone resources. High availability metrics require deploying across multiple Availability Zones (AZs).
- **Service Credits:** The sole and exclusive legal remedy for an SLA breach. CSPs do not reimburse consequential financial damages or lost revenue; they issue non-refundable credits toward future cloud billing cycles.

2.2 Comparative Analysis Across Hyperscalers

Evaluation Dimension	Amazon Web Services (AWS)	Microsoft Azure	Google Cloud Platform (GCP)
Compute (VMs / Multi-Instance)	**99.99%** (EC2 instances across multiple AZs)	**99.99%** (VMs across multiple Availability Zones)	**99.99%** (Instances in multiple zones within same region)
Compute (Single Instance)	**99.5%**	**95.0% - 99.9%** (Depends on disk type: Standard HDD vs. Premium SSD)	**99.5%**
Object Storage Availability	**99.9%** (Amazon S3 Standard; designed for 99.999999999% durability)	**99.9%** (Azure Blob Hot Tier; Read-Access Geo-Redundant	**99.95%** (Standard Cloud Storage multi-region)

		storage up to 99.99%)	
Relational Database Services	**99.95%** (Amazon RDS Multi-AZ deployments)	**99.99%** (Azure SQL Database Business Critical)	**99.95%** (Cloud SQL High Availability configuration)
Remedy Structure	10% credit if < 99.99%; 25% if < 99.0%; 100% if < 95.0%	10% credit if < 99.99%; 25% if < 99.0%; 100% if < 95.0%	10% credit if < 99.99%; 25% if < 99.0%; 50% if < 95.0%
Claim Procedure Window	Customer must submit ticket within 30 days of billing cycle	Customer must submit claim by end of subsequent month	Customer must notify within 30 days of incident

3. Critical SLA Gaps & Operational Vulnerabilities

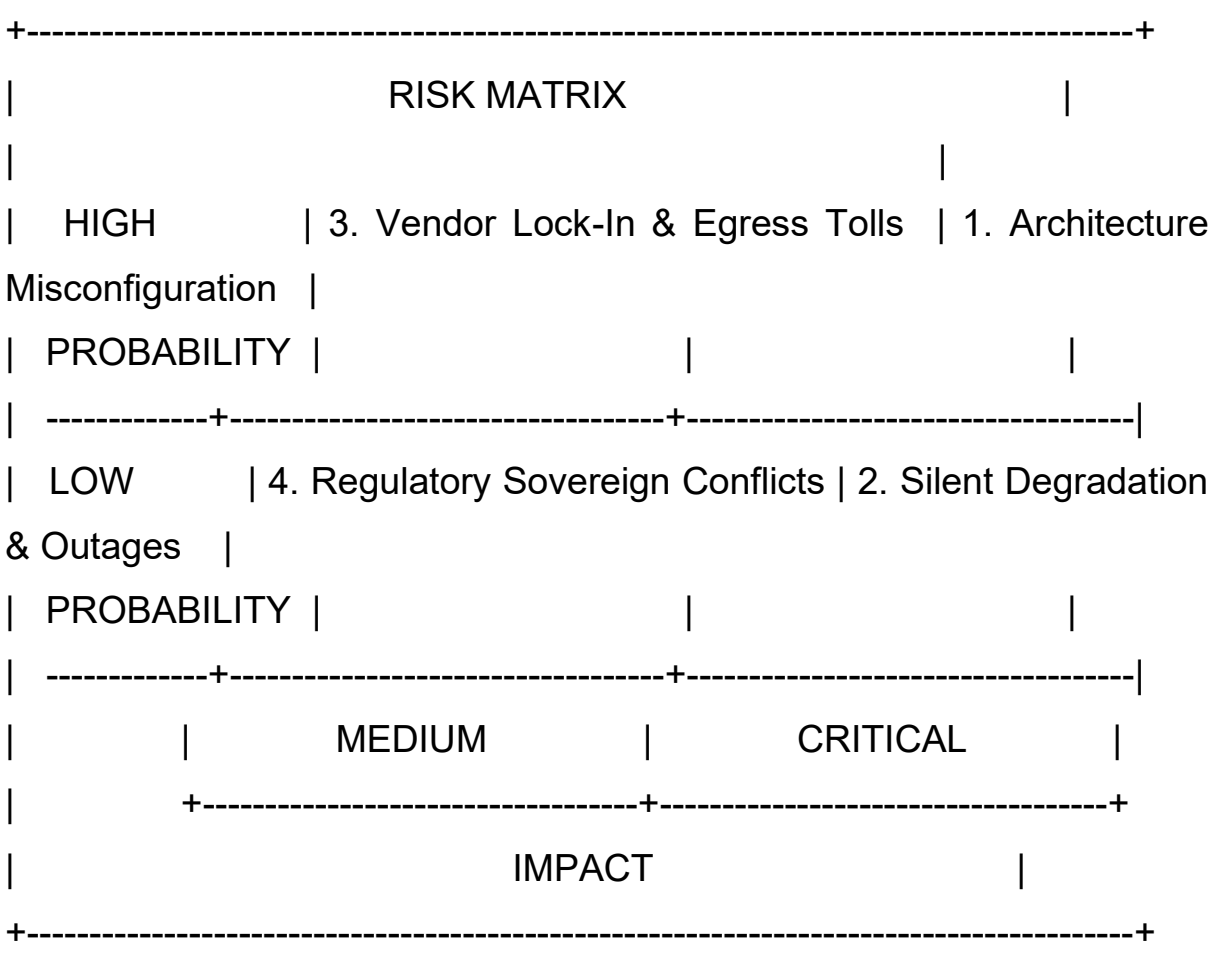
1. **Sole Remedy Limitation:** Standard SLAs protect providers from liability for business disruption. If a retailer loses $2 million in sales during an outage, the cloud provider will only issue a minor billing credit (e.g., $150) for the affected instances.
2. **Customer-Initiated Claim Overhead:** Service credits are **not** credited automatically. The client must independently log downtime, compile evidence from internal monitoring logs, and submit a formal claim within strict deadlines (typically 30 days).
3. **Exclusion Clauses:** Standard SLAs explicitly exclude downtime resulting from:
    - Misconfigurations by customer administrators.

- Distributed Denial of Service (DDoS) attacks saturating ingress pipelines.
- Planned maintenance announced within notice windows.
- Upstream internet service provider (ISP) transit failures outside the CSP's Autonomous System (AS).

4. **Data Durability vs. Data Availability:** An SLA guaranteeing high *durability* (e.g., 99.999999999% for Amazon S3) guarantees against catastrophic bit rot and hardware loss, not against API downtime or regional endpoint unreachability.

4. Risk Assessment & Threat Modeling

An assessment of primary operational risks mapped to standard risk evaluation tiers:



1. **Architecture & Storage Misconfiguration (Critical Impact / High Probability):** Publicly accessible storage buckets, overly broad

security groups, and excessive service role authorizations represent the primary cause of cloud data breaches.

2. **Service Outages & Silent Performance Degradation (Critical Impact / Low-Medium Probability):** Centralized identity service disruptions (e.g., global STS or Entra ID token issuance failures) can incapacitate systems despite Multi-AZ application designs.
3. **Vendor Lock-In & Egress Costs (Medium Impact / High Probability):** Proprietary database engines and substantial network egress fees restrict portability between cloud providers.
4. **Jurisdictional & Compliance Exposure (Critical Impact / Low Probability):** Shifting data residency and extraterritorial laws (such as the US CLOUD Act vs. EU GDPR) can introduce legal liabilities for international customer data.

5. Compliance Framework Alignment

Enterprise cloud deployments require multi-framework compliance validation:

- **ISO/IEC 27001 / 27017 / 27018:** Verifies organizational security controls, specific cloud service configurations, and Personally Identifiable Information (PII) handling within public clouds.
- **SOC 1, SOC 2 Type II, SOC 3:** Standard reports assessing Internal Controls over Financial Reporting (SOC 1) and operational criteria concerning security, availability, and confidentiality over prolonged audit windows (SOC 2 Type II).
- **PCI-DSS (v4.0):** Mandatory for processing, storing, or transmitting cardholder data, enforcing segment isolation and end-to-end encryption.
- **HIPAA / HITECH:** Requires signing a formal **Business Associate Agreement (BAA)** with the CSP before processing protected health information (PHI).

6. Industry-Standard Mitigation Recommendations

- **Multi-Region & Multi-Cloud Architecture:** Build cross-region disaster recovery pipelines (e.g., Active-Passive warm standby or Active-Active route balancing) to prevent single-region SLA outages from halting production.
- **Continuous Monitoring Beyond CSP Dashboards:** Deploy independent synthetic monitoring tools (e.g., Datadog, Prometheus, New Relic) rather than relying exclusively on CSP status dashboards, generating automated telemetry records to support SLA credit claims.
- **Automated Guardrails & Compliance-as-Code:** Use tools such as Open Policy Agent (OPA), AWS Control Tower, or Terraform Sentinel to enforce policy guardrails (e.g., blocking any public S3 bucket or unencrypted volume creation at deployment).
- **Contractual Enterprise Addendums:** Enterprise clients should negotiate custom Business Critical SLAs that include higher uptime commitments, financial penalties that exceed simple billing credits, and automated credit application without manual ticketing.

7. References

1. Amazon Web Services. (2024). *AWS Service Level Agreements Index and Compute SLAs*. AWS Documentation.
2. Microsoft Azure. (2024). *Service Level Agreements (SLA) for Microsoft Online Services*. Microsoft Legal Agreements.
3. Google Cloud. (2024). *Google Cloud Platform Service Level Agreements (SLA)*. Google Cloud Terms.
4. National Institute of Standards and Technology (NIST). (2018). *NIST Special Publication 800-53, Rev. 5: Security and Privacy Controls for Information Systems and Organizations*.

5. International Organization for Standardization (ISO). (2015). *ISO/IEC 27017:2015 Information technology — Security techniques — Code of practice for information security controls based on ISO/IEC 27002 for cloud services*.
6. European Union. (2016). *General Data Protection Regulation (GDPR)*. Regulation (EU) 2016/679.